

- **Expediente N.º: EXP202313871**

RESOLUCIÓN DE TERMINACIÓN DEL PROCEDIMIENTO POR PAGO
VOLUNTARIO

Del procedimiento instruido por la Agencia Española de Protección de Datos y en base a los siguientes

ANTECEDENTES

PRIMERO: Con fecha 8 de julio de 2024, la Directora de la Agencia Española de Protección de Datos acordó iniciar procedimiento sancionador a **COMERCIAL GIRONA DE LLIBRES, S.L.** (en adelante, **COMERCIAL GIRONA**). Notificado el acuerdo de inicio y tras analizar las alegaciones presentadas, con fecha 8 de noviembre de 2024 se emitió la propuesta de resolución que a continuación se transcribe:

<<

Expediente N.º: EXP202313871 (PS/00173/2024)

PROPUESTA DE RESOLUCIÓN DE PROCEDIMIENTO SANCIONADOR

Del procedimiento instruido por la Agencia Española de Protección de Datos y en base a los siguientes

ANTECEDENTES

PRIMERO: **A.A.A.** (en adelante, la parte reclamante) con fecha 21 de junio de 2023 interpuso reclamación ante la Autoridad Catalana de Protección de Datos. Debido a que la entidad que presuntamente podría haber vulnerado la normativa de protección de datos queda fuera del ámbito de actuación de la Autoridad Catalana de Protección de Datos, de acuerdo con lo dispuesto en el artículo 156 de la Ley Orgánica 6/2006, de 19 de julio, de reforma del Estatuto de Autonomía de Cataluña y el artículo 3 de la Ley 32/2010, de 1 de octubre, de la Autoridad Catalana de Protección de Datos, se da traslado de la citada cuestión a esta Agencia, teniendo entrada el 8 de agosto de 2023. La reclamación se dirige contra **COMERCIAL GIRONA DE LLIBRES, S.L.** con NIF **B55192348** (en adelante, **COMERCIAL GIRONA**). Los motivos en que basa la reclamación son los siguientes:

La parte reclamante manifiesta que al registrarse como cliente en <https://comercialgirona.cat/comandes>, el sistema devuelve un mensaje de correo electrónico de confirmación en el que se recoge tanto el usuario (dirección de correo electrónica utilizada en el registro) como la contraseña escogida.

Junto a la reclamación se aporta copia de correo electrónico remitido desde la dirección clients@comercialgirona.cat a la parte reclamante.

SEGUNDO: De conformidad con el artículo 65.4 de la Ley Orgánica 3/2018, de 5 de diciembre, de Protección de Datos Personales y garantía de los derechos digitales (en adelante LOPDGDD), se dio traslado de dicha reclamación a COMERCIAL GIRONA, para que procediese a su análisis e informase a esta Agencia en el plazo de un mes, de las acciones llevadas a cabo para adecuarse a los requisitos previstos en la normativa de protección de datos.

El traslado, que se practicó conforme a las normas establecidas en la Ley 39/2015, de 1 de octubre, del Procedimiento Administrativo Común de las Administraciones Públicas (en adelante, LPACAP), fue recogido en fecha 9 de octubre de 2023 como consta en el acuse de recibo que obra en el expediente.

Con fecha 8 de noviembre de 2023 se recibe en esta Agencia escrito de respuesta indicando que no considera que exista una vulneración de la seguridad, pues no se ha visto comprometida ni la integridad, ni la confidencialidad ni la disponibilidad de la información puesta a disposición del usuario. En este tratamiento interviene un encargado de tratamiento, del cual obtuvieron la siguiente respuesta: Las contraseñas introducidas por el usuario en el momento del registro permanecían cifradas y que nadie más que la persona usuaria podía conocer cuál era la contraseña creada.

Según el encargado de tratamiento: *"El software de comercio electrónico Prestashop, en su versión 1.6, cuando te das de alta como cliente envía una copia de los datos del registro al propio cliente.*

Este email sólo se envía al cliente que ha introducido los datos. No se envía a nadie más, ni se guarda copia en ningún sitio.

Esta es la función de php que envía el email de bienvenida. Sólo se envía al email del propio cliente (customer email) y nadie más..."

TERCERO: Con fecha 8 de noviembre de 2023, de conformidad con el artículo 65 de la LOPDGDD, se admitió a trámite la reclamación presentada por la parte reclamante.

CUARTO: Con fecha 8 de julio de 2024, la Directora de la Agencia Española de Protección de Datos acordó iniciar procedimiento sancionador a COMERCIAL GIRONA, con arreglo a lo dispuesto en los artículos 63 y 64 de la LPACAP, por la supuesta infracción del artículo 32 del RGPD, tipificada en el artículo 83.4.a) de dicha norma, en el que se le indicaba que tenía un plazo de diez días para presentar alegaciones.

Este acuerdo de inicio, que se notificó a COMERCIAL GIRONA conforme a las normas establecidas en la Ley 39/2015, de 1 de octubre, del Procedimiento Administrativo Común de las Administraciones Públicas (LPACAP), fue recogido en fecha 22 de julio de 2024, como consta en el acuse de recibo que obra en el expediente.

QUINTO: Con fecha 24 de julio de 2024, COMERCIAL GIRONA presenta un escrito a través del cual solicita la ampliación del plazo para aducir alegaciones.

SEXTO: Con fecha 30 de julio de 2024, el órgano instructor del procedimiento acuerda la ampliación de plazo instada hasta un máximo de cinco días, de acuerdo con lo dispuesto en el artículo 32.1 de la LPACAP.

El citado acuerdo se notifica a COMERCIAL GIRONA en fecha 30 de julio de 2024, como consta en el acuse de recibo que obra en el expediente.

SÉPTIMO: Con fecha 2 de agosto de 2024, se recibe en esta Agencia, en tiempo y forma, escrito de COMERCIAL GIRONA en el que aduce alegaciones al acuerdo de inicio en el que, en síntesis, manifestaba que:

- Desde el inicio de sus actividades, se ha comprometido a cumplir con la normativa de protección de datos y ha implementado una política de privacidad, procesos de control, y medidas técnicas y organizativas para garantizar la seguridad de los datos personales.

- : Como responsable del tratamiento de los datos, trata los datos de manera confidencial y observa las obligaciones normativas, con especial atención a evitar la alteración, pérdida, tratamiento o acceso no autorizado a dichos datos.

- La empresa detalla las medidas de seguridad que ha implementado, tales como un modelo de gestión de protección de datos que incluye una política de privacidad vinculante y procedimientos internos para garantizar la seguridad desde el diseño, el uso de doble autenticación para el acceso a cuentas de clientes y eliminación del envío de contraseñas por correo electrónico a partir de una determinada fecha, el contrato con el encargado del diseño de su plataforma web, que también cumplen con las normativas de seguridad.

Afirma que estas medidas de seguridad son proporcionales al riesgo, que incluyen la seudonimización y el cifrado, y que realiza evaluaciones regulares de sus sistemas para garantizar la seguridad. Defiende que su responsabilidad está basada en la adopción de medios razonables y no en la infalibilidad de las medidas adoptadas, aludiendo a la jurisprudencia del Tribunal Supremo que apoya esta perspectiva.

- El propósito del tratamiento es únicamente para el acceso a la web y no para la realización de compras, y que los datos involucrados no son de categorías especiales de carácter personal.

- La empresa argumenta que una sanción de 20.000 euros supondría un grave perjuicio económico, poniendo en riesgo su continuidad y afectando a sus empleados, dadas las pérdidas económicas de los últimos años.

OCTAVO: Se acompaña como anexo relación de documentos obrantes en el procedimiento.

De las actuaciones practicadas en el presente procedimiento y de la documentación obrante en el expediente, han quedado acreditados los siguientes:

HECHOS PROBADOS

PRIMERO: Con fecha 6 de octubre de 2023, se recoge por esta Agencia evidencia de “Aviso Legal y Política de Privacidad” de la web <https://comercialgirona.cat/comandes/es/content/3-aviso-legal>.

En este “Aviso Legal y Política de Privacidad” consta lo siguiente:

*“De acuerdo con lo establecido en el Reglamento General de Protección de Datos, le informamos que trataremos sus datos personales con la finalidad de:
Venta de nuestros productos online, e informarle sobre los productos o servicios publicados en nuestra web.*

[...]

Así mismo, le informamos de la posibilidad de ejercer los siguientes derechos sobre sus datos personales: derecho de acceso, rectificación, supresión u olvido, limitación, oposición, portabilidad y retirar el consentimiento prestado, enviando un correo electrónico a clients@comercialgirona.cat

[...]

continuación se detallan los datos identificativos de la entidad:

Razón social: COMERCIAL GIRONA DE LLIBRES SL

NIF: B55192348

Dirección: Avda. Mas Vila, 142 - 17457 - RIUDELLOTS DE LA SELVA - GIRONA

Teléfono: 972477695

Mail: clients@comercialgirona.cat”

SEGUNDO: Consta en el expediente imagen de mensaje de correo electrónico, aportado por la parte reclamante junto con la reclamación, con el siguiente contenido:

“Comercial Girona de Llibres <clients@comercialgirona.cat>

*Para **A.A.A.***

*HOLA **A.A.A.**,*

GRACIAS POR CREAR UNA CUENTA DE CLIENTE EN COMERCIAL GIRONA DE LLIBRES

DETALLES DE SU CUENTA EN COMERCIAL GIRONA DE LLIBRES

Estos son sus datos de acceso:

*Dirección de correo electrónico: ***EMAIL.1*

Contraseña: XXXXXX

Ahora podrá realizar pedidos en nuestra tienda: Comercial Girona de Llibres”

Según refiere COMERCIAL GIRONA en su escrito de 8 de noviembre de 2023, en el que da respuesta al traslado formulado por esta Agencia:

“El 21 de junio del año 2023 un usuario (denunciante) se da de alta en la página web del responsable (COMERCIAL GIRONA DE LLIBRES) para poder realizar las diversas comandas de libros de textos conforme le han indicado en su centro escolar.”

TERCERO: En el escrito de 8 de noviembre de 2023, COMERCIAL GIRONA describe el proceso de alta de los usuarios de su web:

“En el proceso de alta, el usuario se registra con los datos obligatorios que le son solicitados, todos ellos necesarios para poder tramitar y gestionar la reserva y posterior compra del pedido, estos datos de registro son: nombre y apellidos, correo electrónico de contacto, contraseña (a elegir por el usuario), código del centro para identificar la compra, dirección de facturación y DNI.

- Una vez registrado el usuario y dado de alta correctamente, el sistema genera un correo electrónico de confirmación de alta de usuario, con los datos de acceso (usuario y contraseña) ...”

CUARTO: Con relación de la consulta realizada por la parte reclamante a COMERCIAL GIRONA, en su escrito de 8 de noviembre de 2023, la reclamada declara lo siguiente:

“...poniéndose en contacto el usuario con el responsable pidiendo explicaciones de tal envío de la confirmación de datos de acceso.

- El responsable, inmediatamente se pone en contacto con el usuario y le explica que nadie de la organización ni desarrolladores de la página web tiene acceso a las contraseñas de los usuarios, pues éstas se encuentran encriptadas y solo tendrá conocimiento el usuario que hizo el registro.

- Se dio por resulta la consulta ...”

QUINTO: En el listado de tratamientos propios del responsable COMERCIAL GIRONA, aportado junto con las alegaciones al acuerdo de inicio, consta el siguiente tratamiento de datos personales:

[...]“

Nombre: Usuarios web venta online

[...]“

Responsable: COMERCIAL GIRONA DE LLIBRES, SL

Finalidad: Gestión de las ventas online a los usuarios que compren un producto o servicio en la web de la empresa.

[...]“

Colectivos de interesados: Usuarios. Personas que accedan a la web de la empresa vía internet

Categorías de datos: De identificación: Nombre y apellidos, NIF, Dirección postal o electrónica, teléfono. Datos bancarios: Para el cargo en TC o domiciliación de pagos. Otros: IP, Nombre de usuario. Aquí se incluye tu firma digital y electrónica y los códigos o claves que utilizas para acceder y operar en nuestra página web.

[...]”

SEXTO: En la carta informativa que se envía a la AFA, aportada por COMERCIAL GIRONA en sus alegaciones al acuerdo de inicio, se dice lo siguiente (original en catalán):

“LIBROS DE TEXTO 2023/2024

Estimadas familias,

A continuación, le indicamos cómo realizar la compra de libros y material para el próximo curso:

ACCESO A LA WEB

www.comercialgirona.cat/pedidos

Código centro: (...)

IMPORTANTE: Debe registrarse en la página web aunque ya lo hiciera el año pasado.

Plazo de acceso a la web: del 15 de junio al 20 de julio

[...]”

SÉPTIMO: De acuerdo con el informe recogido de la herramienta AXESOR, la entidad COMERCIAL GIRONA DE LLIBRES, S.L. es una microempresa, constituida en el año 2014, y con un volumen de negocios de (...) euros en el año 2022

FUNDAMENTOS DE DERECHO

I

Competencia

De acuerdo con los poderes que el artículo 58.2 del Reglamento (UE) 2016/679 (Reglamento General de Protección de Datos, en adelante RGPD), otorga a cada autoridad de control y según lo establecido en los artículos 47, 48.1, 64.2 y 68.1 de la Ley Orgánica 3/2018, de 5 de diciembre, de Protección de Datos Personales y garantía de los derechos digitales (en adelante, LOPDGDD), es competente para iniciar y resolver este procedimiento la Directora de la Agencia Española de Protección de Datos.

Asimismo, el artículo 63.2 de la LOPDGDD determina que: *“Los procedimientos tramitados por la Agencia Española de Protección de Datos se regirán por lo dispuesto en el Reglamento (UE) 2016/679, en la presente ley orgánica, por las disposiciones*

reglamentarias dictadas en su desarrollo y, en cuanto no las contradigan, con carácter subsidiario, por las normas generales sobre los procedimientos administrativos."

II

Cuestiones previas

En el presente caso, de acuerdo con lo establecido en el artículo 4.1 y 4.2 del RGPD, consta la realización de un tratamiento de datos personales, toda vez que COMERCIAL GIRONA, como responsable del tratamiento, realiza la recogida, conservación y comunicación de, entre otros, los siguientes datos personales de personas físicas: nombre, correo electrónico y contraseña de los clientes, entre otros tratamientos.

COMERCIAL GIRONA realiza esta actividad en su condición de responsable del tratamiento, dado que es quien determina los fines y medios de tal actividad, en virtud del artículo 4.7 del RGPD.

En el artículo 32 del RGPD se regulan las medidas de seguridad que deben adoptarse para garantizar un nivel de seguridad adecuado al riesgo que presente el tratamiento de datos personales.

III

Medidas de seguridad

El artículo 32 "Seguridad del tratamiento" del RGPD establece:

"1. Teniendo en cuenta el estado de la técnica, los costes de aplicación, y la naturaleza, el alcance, el contexto y los fines del tratamiento, así como riesgos de probabilidad y gravedad variables para los derechos y libertades de las personas físicas, el responsable y el encargado del tratamiento aplicarán medidas técnicas y organizativas apropiadas para garantizar un nivel de seguridad adecuado al riesgo, que en su caso incluya, entre otros:

a) la seudonimización y el cifrado de datos personales;

b) la capacidad de garantizar la confidencialidad, integridad, disponibilidad y resiliencia permanentes de los sistemas y servicios de tratamiento;

c) la capacidad de restaurar la disponibilidad y el acceso a los datos personales de forma rápida en caso de incidente físico o técnico;

d) un proceso de verificación, evaluación y valoración regulares de la eficacia de las medidas técnicas y organizativas para garantizar la seguridad del tratamiento.

2. Al evaluar la adecuación del nivel de seguridad se tendrán particularmente en cuenta los riesgos que presente el tratamiento de datos, en particular como

consecuencia de la destrucción, pérdida o alteración accidental o ilícita de datos personales transmitidos, conservados o tratados de otra forma, o la comunicación o acceso no autorizados a dichos datos.

3. La adhesión a un código de conducta aprobado a tenor del artículo 40 o a un mecanismo de certificación aprobado a tenor del artículo 42 podrá servir de elemento para demostrar el cumplimiento de los requisitos establecidos en el apartado 1 del presente artículo.

4. El responsable y el encargado del tratamiento tomarán medidas para garantizar que cualquier persona que actúe bajo la autoridad del responsable o del encargado y tenga acceso a datos personales solo pueda tratar dichos datos siguiendo instrucciones del responsable, salvo que esté obligada a ello en virtud del Derecho de la Unión o de los Estados miembros”.

En el correo electrónico remitido por COMERCIAL GIRONA a la parte reclamante en el que se le comunica el alta como cliente, se recoge, además del correo electrónico de alta, la contraseña del usuario.

Con relación a la seguridad del correo electrónico, el “Informe de buenas prácticas” de mayo de 2021, CNN-CERT BP02, del Centro Criptológico Nacional, servicio adscrito al Centro Nacional de Inteligencia, cuya misión es contribuir a la mejora de la ciberseguridad española, recoge una serie de vulnerabilidades del correo electrónico y de las diversas formas en que éstos pueden ser atacados, así como recomendaciones de seguridad. En el apartado 4.2 de dicho Informe se describe la “Seguridad de las comunicaciones vía email”, con las siguientes aseveraciones en sus páginas 37 a 39: “El protocolo involucrado en este proceso de envío es SMTP. Este protocolo ha sido utilizado desde 1982 y cuando fue implementando no se tuvieron en cuenta medidas de seguridad tales como el cifrado o la autenticación de las comunicaciones. Esto quiere decir que todo el proceso de envío descrito anteriormente se realizaría en texto plano, es decir, que en cualquier punto de la transmisión un atacante podría ver y manipular el contenido de los correos. Debido a estas carencias en SMTP se han ido desarrollando diversas tecnologías y extensiones que permiten incorporar medidas de seguridad para garantizar la autenticación, integridad y cifrado a las comunicaciones vía correo electrónico. Algunas de las tecnologías más conocidas son STARTTLS, SPF, DKIM y DMARC... Aunque los proveedores de correo más conocidos como Google, Yahoo y Outlook cifran y autentican los emails utilizando este tipo de tecnologías, muchas organizaciones siguen haciendo un uso descuidado del correo electrónico. Téngase en cuenta, además, que estas tecnologías deben ser implementadas tanto en el origen como en el destino para que puedan utilizarse. Asimismo, algunas de estas medidas son susceptibles de ser atacadas. Por ejemplo, STARTTLS es susceptible a ataques downgrade, en donde un atacante en una situación man-in-the-middle puede forzar a que no que lleve a cabo la negociación TLS (bastaría con reemplazar la cadena STARTTLS). Incluso en el caso de que se establezca la comunicación TLS de forma satisfactoria, los servidores de correo por los que pasa el email hasta alcanzar el destino tendrían acceso a su contenido. Debido a estos hechos, se deduce que no es suficiente con delegar la seguridad del correo electrónico a las tecnologías subyacentes encargadas de hacer llegar el mismo a su destinatario.”

A tenor de las carencias de seguridad señaladas anteriormente, se pone de manifiesto que el correo electrónico no es un medio adecuado para garantizar la integridad y confidencialidad en el envío de datos personales, suponiendo un riesgo para los clientes de COMERCIAL GIRONA, a quienes se les envía su contraseña junto con el usuario por correo electrónico cuando se dan de alta en la web de la citada entidad. El hecho de que el email sólo se envíe al cliente que ha introducido los datos, no es garantía de que los datos no puedan ser interceptados.

Por otra parte, el envío de las contraseñas al correo electrónico de los clientes de COMERCIAL GIRONA supone que puedan ser almacenadas en dicho medio, lo cual constituye una práctica que puede suponer un riesgo para los clientes, ya que dichas contraseñas, junto con los respectivos usuarios, serían vulnerables a cualquier tipo de ataque informático. De nada serviría que se conserven encriptadas por COMERCIAL GIRONA, tal y como refiere en su respuesta al traslado de la reclamación, cuando en los correos electrónicos de sus clientes no tendrían ningún tipo de protección adicional.

Hay que señalar que el RGPD no establece un listado de las medidas de seguridad que sean de aplicación de acuerdo con los datos que son objeto de tratamiento, sino que, en virtud del principio de responsabilidad proactiva del artículo 5.2 del propio RGPD, el cual comporta la exigencia de que el responsable del tratamiento asegure la efectiva privacidad e integridad de los datos, tanto el responsable como el encargado del tratamiento aplicarán medidas técnicas y organizativas que sean adecuadas al riesgo que conlleve el tratamiento, teniendo en cuenta el estado de la técnica, los costes de aplicación, la naturaleza, alcance, contexto y finalidades del tratamiento, los riesgos de probabilidad y gravedad para los derechos y libertades de las personas interesadas. Además, el responsable tiene que estar en condiciones de demostrar que ha implantado esas medidas y que las mismas son las adecuadas para lograr la finalidad perseguida.

Asimismo, las medidas de seguridad deben resultar adecuadas y proporcionadas al riesgo detectado, señalando que la determinación de las medidas técnicas y organizativas deberá realizarse teniendo en cuenta: la seudonimización y el cifrado, la capacidad para garantizar la confidencialidad, integridad, disponibilidad y resiliencia, la capacidad para restaurar la disponibilidad y acceso a datos tras un incidente, proceso de verificación (que no auditoría), evaluación y valoración de la eficacia de las medidas.

En todo caso, al evaluar la adecuación del nivel de seguridad se tendrán particularmente en cuenta los riesgos que presente el tratamiento de datos, como consecuencia de la destrucción, pérdida o alteración accidental o ilícita de datos personales transmitidos, conservados o tratados de otra forma, o la comunicación o acceso no autorizados a dichos datos y que pudieran ocasionar daños y perjuicios físicos, materiales o inmateriales.

En este mismo sentido el considerando 83 del RGPD señala que:

“(83) A fin de mantener la seguridad y evitar que el tratamiento infrinja lo dispuesto en el presente Reglamento, el responsable o el encargado deben evaluar los riesgos inherentes al tratamiento y aplicar medidas para mitigarlos, como el cifrado. Estas

medidas deben garantizar un nivel de seguridad adecuado, incluida la confidencialidad, teniendo en cuenta el estado de la técnica y el coste de su aplicación con respecto a los riesgos y la naturaleza de los datos personales que deben protegerse. Al evaluar el riesgo en relación con la seguridad de los datos, se deben tener en cuenta los riesgos que se derivan del tratamiento de los datos personales, como la destrucción, pérdida o alteración accidental o ilícita de datos personales transmitidos, conservados o tratados de otra forma, o la comunicación o acceso no autorizados a dichos datos, susceptibles en particular de ocasionar daños y perjuicios físicos, materiales o inmateriales”.

Por todo lo expuesto, debe considerarse que las medidas técnicas y organizativas aplicadas por COMERCIAL GIRONA en la comunicación por correo electrónico de la creación de una cuenta de cliente por la parte reclamante no garantizan un nivel de seguridad adecuado al riesgo, debido a que el correo electrónico no puede considerarse un medio apropiado para el envío y conservación de contraseñas de usuarios, y, en mayor grado, cuando se envía de forma conjunta el usuario a quien pertenece.

De conformidad con las evidencias de las que se dispone en este momento de propuesta de resolución del procedimiento sancionador, se considera que los hechos conocidos podrían ser constitutivos de una infracción, imputable a COMERCIAL GIRONA, por vulneración del artículo 32 del RGPD.

IV

Tipificación de la infracción del artículo 32

La citada infracción del artículo 32 del RGPD supone la comisión de las infracciones tipificadas en el artículo 83.4 del RGPD que bajo la rúbrica “*Condiciones generales para la imposición de multas administrativas*” dispone:

“Las infracciones de las disposiciones siguientes se sancionarán, de acuerdo con el apartado 2, con multas administrativas de 10 000 000 EUR como máximo o, tratándose de una empresa, de una cuantía equivalente al 2 % como máximo del volumen de negocio total anual global del ejercicio financiero anterior, optándose por la de mayor cuantía:

a) las obligaciones del responsable y del encargado a tenor de los artículos 8, 11, 25 a 39, 42 y 43; (...)”

A este respecto, la LOPDGDD, en su artículo 71 “*Infracciones*” establece que “*Constituyen infracciones los actos y conductas a las que se refieren los apartados 4, 5 y 6 del artículo 83 del Reglamento (UE) 2016/679, así como las que resulten contrarias a la presente ley orgánica*”.

A efectos del plazo de prescripción, el artículo 73 “*Infracciones consideradas graves*” de la LOPDGDD indica:

“En función de lo que establece el artículo 83.4 del Reglamento (UE) 2016/679 se consideran graves y prescribirán a los dos años las infracciones que supongan una

vulneración sustancial de los artículos mencionados en aquel y, en particular, las siguientes:

(...)

f) La falta de adopción de aquellas medidas técnicas y organizativas que resulten apropiadas para garantizar un nivel de seguridad adecuado al riesgo del tratamiento, en los términos exigidos por el artículo 32.1 del Reglamento (UE) 2016/679.

V

Sanción por la infracción del artículo 32 del RGPD

A efectos de decidir sobre la imposición de una multa administrativa y su cuantía, de conformidad con las evidencias de que se dispone en el presente momento de acuerdo de inicio de procedimiento sancionador, y sin perjuicio de lo que resulte de la instrucción, se considera que procede graduar la sanción a imponer de acuerdo con los siguientes criterios que establece el artículo 83.2 del RGPD:

Como circunstancias del 83.2 del RGPD a efectos de determinar el grado de gravedad de la infracción:

- La naturaleza, gravedad y duración de la infracción, teniendo en cuenta la naturaleza, alcance o propósito de la operación de tratamiento de que se trate (apartado a): La responsabilidad de la infracción cometida por COMERCIAL GIRONA se ve incrementada porque el propósito del tratamiento está relacionado con la actividad principal del responsable del mismo.
- Las categorías de los datos de carácter personal afectados por la infracción (apartado g): Al tratarse de la contraseña para identificarse en una web, es un dato que debe estar especialmente protegido. De otro modo, cualquier acceso a este dato por terceros no autorizados, supone un riesgo de suplantación de la identidad del usuario en uso de la web de COMERCIAL GIRONA.

Asimismo, se considera que procede graduar la sanción a imponer de acuerdo con los siguientes criterios que establece el apartado 2 del artículo 76 “Sanciones y medidas correctivas” de la LOPDGDD:

Como agravante:

- La vinculación de la actividad del infractor con la realización de tratamientos de datos personales (apartado b): El desarrollo de la actividad empresarial que desempeña COMERCIAL GIRONA, mediante la venta de libros por internet, requiere un tratamiento continuo de datos personales de aquellos clientes que se registran en su página web.

El balance de las circunstancias contempladas en el artículo 83.2 del RGPD y 76.2 de la LOPDGDD, con respecto a la infracción cometida al vulnerar lo establecido en el artículo 32 del RGPD, permite proponer una sanción de 20.000 € (veinte mil euros).

VI

Contestación a las alegaciones aducidas al acuerdo de inicio

Con relación a las alegaciones aducidas por COMERCIAL GIRONA al acuerdo de inicio, se procede a dar respuesta a las mismas según el orden en que se exponen en su escrito:

“PRIMERA”

Según COMERCIAL GIRONA, desde el inicio de sus actividades se ha comprometido a cumplir con la normativa de protección de datos, y ha implementado una política de privacidad, procesos de control, y medidas técnicas y organizativas para garantizar la seguridad de los datos personales.

Sin perjuicio de todas estas medidas implementadas para el cumplimiento de la normativa de protección de datos, hasta que se inició el presente procedimiento COMERCIAL GIRONA no había adoptado ninguna medida específica de carácter técnico u organizativo destinada a garantizar un nivel de seguridad adecuado al riesgo, evitando que un correo electrónico que se envía de forma automática cuando un usuario se dé de alta en su web, contenga a su vez el usuario y la contraseña, pese a que la parte reclamante se puso en contacto con COMERCIAL GIRONA para poner de manifiesto el error de esta circunstancia, tal y como describe la propia reclamada en la respuesta al traslado de la reclamación *“...poniéndose en contacto el usuario con el Responsable pidiendo explicaciones de tal envío de la confirmación de datos de acceso”*. La única medida adoptada por COMERCIAL GIRONA fue comunicar a la parte reclamante que *“nadie de la organización ni desarrolladores de la página web tiene acceso a las contraseñas de los usuarios, pues éstas se encuentran encriptadas y solo tendrá conocimiento el usuario que hizo el registro”*.

Por todo lo expuesto, se desestima la presente alegación

“SEGUNDA: Cronología del proceso de alta de cliente:”

En esta alegación, COMERCIAL GIRONA explica el proceso de alta de cliente, con una “doble autenticación”, a través de la contraseña asignada al centro educativo y el usuario y contraseña mediante el registro del propio cliente. Por último, para el proceso de compra, COMERCIAL GIRONA no solicita ninguna información de carácter bancario ni personal.

Como respuesta a estos argumentos, en primer lugar, cabe resaltar que la preparación y envío de la carta informativa en el que se contiene el código de centro y su posterior distribución entre las familias de los alumnos carece de medidas de seguridad y no existen instrucciones respecto a los centros educativos, quedando a su libre elección: *“La entrega de esta carta a las familias la realiza el propio centro de diversas formas (dependiendo del método escogido por cada centro), léase, correo electrónico, aplicación interna de la escuela, mensajería instantánea de la AFA o en formato papel.”*

Por lo tanto, si bien el uso de la “doble contraseña” supone una medida reforzada en cuanto al acceso a la web de COMERCIAL GIRONA, la falta de medidas de seguridad en la comunicación de código de centro, hace que esta medida adolezca de garantías adecuadas. Además, este código de centro es conocido por todas las familias de cada centro, y no existe garantía de que no pueda ser difundido sin control alguno.

Con independencia del uso del código de centro, el envío del usuario y la contraseña en el mismo correo electrónico no deja de ser un riesgo para los usuarios registrados en la web de COMERCIAL GIRONA.

Por último, el argumento de que no se exige ninguna información de carácter bancario ni personal en el alta en la web, se contradice con lo dispuesto en el Registro de Actividades de Tratamiento proporcionado por COMERCIAL GIRONA, con relación al tratamiento “usuarios web venta online”, donde se mencionan las siguientes categorías de datos objeto de tratamiento: *De identificación: Nombre y apellidos, NIF, Dirección postal o electrónica, teléfono. Datos bancarios: Para el cargo en TC o domiciliación de pagos. Otros: IP, Nombre de usuario. Aquí se incluye tu firma digital y electrónica y los códigos o claves que utilizas para acceder y operar en nuestra página web.* Además, el usuario y contraseña del cliente enviados por correo electrónico de forma conjunta, también constituyen datos personales.

Por todo lo expuesto, la presente alegación queda desestimada.

“TERCERA: Medidas de Seguridad implementadas”

En este punto, COMERCIAL GIRONA quiere reseñar una serie de medidas de seguridad que se adecuan en función del riesgo detectado, habiendo procedido a eliminar el envío de contraseñas por correo electrónico, así como una serie de pantallas demostrativas de la necesidad de contar con el Código de Centro para darse de alta en la plataforma web, de la existencia de una “vigencia de acceso” para operar con la cuenta y, por último, del código fuente donde se refleja el proceso de encriptación.

Aunque la empresa alega que el envío de contraseñas junto con el usuario ha sido eliminado, la práctica previa de enviarlas sigue siendo relevante a efectos de determinar la comisión de la infracción. En este sentido, COMERCIAL GIRONA continuó con esta práctica pese a que, en su respuesta al traslado de la reclamación, reconocen que la parte reclamante se puso en contacto con ellos para pedirles explicaciones sobre esta forma de acceso. En consecuencia, la eliminación de la práctica del envío de usuario y contraseña en un mismo correo electrónico supone el cumplimiento de la medida provisional impuesta en el Fundamento de Derecho VI del acuerdo de inicio del presente procedimiento, no pudiendo admitirse como argumento para modular la responsabilidad administrativa.

Las capturas de las pantallas demostrativas vienen a ilustrar las ideas desarrolladas en la alegación “SEGUNDA”, por lo que los argumentos expuestos en respuesta a

dicha alegación, como la falta de seguridad de la entrega del “código centro”, pueden traerse a colación respecto a las imágenes del proceso de alta.

Asimismo, se remite captura de pantalla (...).

Por todo lo expuesto, la presente alegación queda desestimada.

“CUARTA.”

COMERCIAL GIRONA presenta información y documentación adicional acerca de medidas de seguridad por defecto y desde el diseño, en todas las acciones de nuevos clientes, bajo una estructura de diversificación de riesgos. Vuelve a reproducir la carta remitida a los centros con el código centro, se aporta el contrato con el encargado de tratamiento y los enlaces de las condiciones legales de la herramienta con lo que hizo su web.

Sin embargo, a pesar de estas medidas, el envío de credenciales por correo electrónico supone una vulneración del artículo 32 del RGPD, que exige la adopción de medidas de seguridad adecuadas al riesgo. La falta de medidas adecuadas pone en riesgo los datos personales de los clientes, y se considera que la empresa no implementó medidas organizativas o técnicas suficientes para proteger los datos sensibles en el proceso de transmisión, remitiendo usuario y contraseña en el mismo correo electrónico.

Por todo lo expuesto, la presente alegación queda desestimada.

“QUINTA.- Comunicación de la solución al perjudicado.”

En esta alegación COMERCIAL GIRONA resume alguna de las ideas expuestas anteriormente con son el uso de la “doble contraseña” para el acceso a su web y que en la plataforma no se guardan datos bancarios de los clientes. Según COMERCIAL GIRONA, aunque dicha contraseña se hubiera visto expuesta, no produciría ningún daño o perjuicio al titular de los datos, aunque el concepto de riesgo cero no existe puesto que siempre existe un riesgo inherente que una vez se han aplicado las medidas y garantías se minimizan, COMERCIAL GIRONA en las etapas de concepción y el diseño del ciclo de vida de este tratamiento definió y aplicó una serie de controles para reducir la probabilidad o el impacto de los factores de riesgos identificados.

En respuesta a este argumento, cabe señalar que la parte reclamante afirma en su reclamación lo siguiente: *“evidentemente tengo dudas de la seguridad de esta empresa en cuanto a los datos bancarios usados para la compra del material escolar”*, por lo que sí parece que, además de otros datos personales, también se recogen en el alta en la web de COMERCIAL GIRONA datos personales de carácter financiero. Esto se confirma con lo dispuesto en el Registro de Actividades de Tratamiento proporcionado por COMERCIAL GIRONA, con relación al tratamiento “usuarios web venta online”, donde se mencionan las siguientes categorías de datos objeto de

tratamiento, entre los que se encuentran “datos bancarios: Para el cargo en TC o domiciliación de pagos”.

Aunque no se haya materializado un daño económico o fraude directamente, la exposición del usuario y la contraseña en el mismo correo electrónico supone un riesgo significativo para la integridad y confidencialidad de los datos. Este hecho es especialmente relevante si se tiene en cuenta que la transmisión de datos a través de correos electrónicos no cifrados o mediante protocolos inseguros (como SMTP sin cifrado TLS) podría facilitar la interceptación de las credenciales.

Tal como lo indica el Considerando 83 del RGPD, las medidas de seguridad deben garantizar un nivel de seguridad adecuado, incluida la confidencialidad. El artículo 32 del RGPD establece la obligación de que los responsables implementen medidas técnicas y organizativas adecuadas para evitar este tipo de riesgos, especialmente en escenarios de transmisión de datos sensibles como contraseñas.

Pese a que COMERCIAL GIRONA argumente que se utilizó un doble factor de autenticación y que las credenciales no pueden ser usadas por sí solas, el hecho de enviar ambos elementos juntos en un medio vulnerable (correo electrónico) debilita considerablemente la seguridad de esos datos. El RGPD no se limita a las consecuencias materiales del riesgo, sino que también toma en cuenta la probabilidad y la gravedad del riesgo en términos de accesos no autorizados, daño reputacional y otros posibles perjuicios inmateriales.

En consecuencia, a diferencia de lo expresado por COMERCIAL GIRONA, la remisión del usuario y contraseña en un único correo sin ningún tipo de medida de seguridad, supone la falta de un sistema robusto para evitar riesgos a los datos personales, lo que confirma la responsabilidad de la empresa, incluso sin que se haya producido un daño directo, debido a que la falta de diligencia en la implementación de medidas de seguridad pone en riesgo los derechos de los interesados.

Por todo lo expuesto, se desestima la presente alegación.

“En relación con la Diligencia debida.”

En este apartado, COMERCIAL GIRONA alega una serie de medidas implementadas, tales como la doble contraseña, el registro de actividades de tratamiento, el análisis de riesgo y el contrato del encargado en lo referente a la seguridad del tratamiento, quedando atendida la obligación de medios que establece el art. 32 del RGPD.

COMERCIAL GIRONA es la responsable del tratamiento y, como tal, tiene la obligación de garantizar la seguridad de los datos en todo el proceso, desde su recogida hasta su conservación y transmisión. El hecho de que una parte del proceso involucre a un encargado de tratamiento, no exime a la empresa de esta responsabilidad, ya que debe demostrar que ha implementado, y continúa evaluando, medidas de seguridad que respondan a los riesgos actuales y emergentes, lo cual no ha sucedido en este caso

El RGPD, en su artículo 32, exige que las medidas de seguridad sean proporcionales al riesgo y adecuadas para garantizar la confidencialidad de los datos. Enviar tanto el usuario como la contraseña en el mismo correo electrónico supone una vulnerabilidad grave. En caso de que dicho correo fuera interceptado, un atacante tendría acceso a las credenciales completas, lo que permitiría suplantar la identidad del cliente en la plataforma.

Una práctica habitual para proteger la seguridad de las cuentas es no enviar credenciales juntas, y en muchos casos se opta por no enviar la contraseña en texto sin encriptar, sino por un enlace temporal para que el usuario establezca su propia contraseña. El RGPD no obliga a una medida específica, pero estas son prácticas ampliamente utilizadas como mínimas medidas de seguridad en el de tratamiento de datos.

El hecho de que no se hayan producido consecuencias negativas inmediatas no elimina la gravedad del incumplimiento, ni exime a la empresa de su responsabilidad por adoptar medidas de seguridad insuficientes. El riesgo de vulneración de datos sigue presente y podría ocasionar daños futuros.

Precisamente, la STS núm. 188/2022 a que se refiere COMERCIAL GIRONA, en sus alegaciones establece que, en cuestiones de protección de datos, las medidas de seguridad son obligaciones de medios y no de resultados. Esto significa que la empresa debe demostrar que ha implementado medidas adecuadas en todo momento, independientemente de si el fallo en seguridad ha tenido consecuencias efectivas o no.

Por todo lo expuesto, se desestima la presente alegación.

“SEXTA.-“

COMERCIAL GIRONA pone en cuestión los factores que agravan su responsabilidad en el objeto del presente procedimiento, motivando que el propósito del tratamiento es validarse en la web, que no permite avanzar en la compra sin el uso del “código de centro”. Afirma que no se está hablando de categoría especiales de datos y que cualquier acceso a este dato por terceros no autorizados, no supone ningún riesgo presente ni futuro de suplantación de la identidad del usuario, estando limitada la vigencia de estas contraseñas es de únicamente 1,5 meses, es decir 45 días,

Sin embargo, el modelo de carta informativa que se adjunta a las alegaciones, bajo el título “LLIBRES DE TEXT 2023/2024”, sí explica que el código de centro es facilitado para realizar la compra de libros, junto con el alta en la web, que hay que repetir aunque se hubiera hecho el año anterior, por lo que el tratamiento del tratamiento sí tiene la finalidad de realizar la compra de libros.

Respecto a la categoría de datos tratados, la parte reclamante afirma en su reclamación lo siguiente: *“evidentemente tengo dudas de la seguridad de esta empresa en cuanto a los datos bancarios usados para la compra del material escolar”*, y en el Registro de Actividades de Tratamiento proporcionado por COMERCIAL GIRONA, con relación al tratamiento *“usuarios web venta online”*, se mencionan las

categorías de datos objeto de tratamiento, entre los que se encuentran “*datos bancarios: Para el cargo en TC o domiciliación de pagos*”.

Como se motivó anteriormente, si bien el uso de la “doble contraseña” supone una medida reforzada en cuanto al acceso a la web de COMERCIAL GIRONA, la falta de medidas de seguridad en la comunicación de código de centro, hace que esta medida adolezca de garantías adecuadas. Además, este código de centro es conocido por todas las familias de cada centro, y no existe garantía de que no pueda ser difundido o utilizado sin control alguno.

Por último, debe tenerse en cuenta la inacción de COMERCIAL GIRONA. Ni la consulta realizada por la parte reclamante ni el traslado de la reclamación han motivado que la empresa modifique el sistema de alta en su web; lo cierto es que hasta la notificación del acuerdo de inicio del presente procedimiento, seguía empleando métodos inseguros. Este hecho sugiere una falta de compromiso con la mejora continua y con la responsabilidad proactiva que exige el RGPD.

Por todo lo expuesto, se desestima la presente alegación.

“SÉPTIMA.-“

En esta alegación, COMERCIAL GIRONA sostiene que en el establecimiento del importe de la sanción es desproporcionado dada su capacidad económica, no habiéndose tenido en cuenta que sus ingresos de los últimos años se han visto muy perjudicados por las circunstancias sociales y sanitarias vividas a consecuencia de la pandemia

En respuesta a este argumento, cabe señalar que el importe de la infracción se calculado conforme a lo dispuesto en el artículo 83.4.a) del RGPD, y teniendo en cuenta el balance de las circunstancias contempladas en los artículos 83.2 del RGPD y 76.2 de la LOPDGDD.

El RGPD es claro en que las medidas de seguridad deben ser proporcionales al riesgo, y en este caso, la falta de medidas de seguridad adecuadas, combinada con la práctica de enviar credenciales por correo electrónico, justifica una sanción. La protección de datos no es un derecho relativo, y la sanción busca no solo corregir, sino también disuadir futuras conductas negligentes en la protección de datos personales.

Por todo lo expuesto, se desestima la presente alegación.

VII Imposición de medidas

De confirmarse la infracción, procede imponer a la parte reclamada la obligación de adoptar medidas adecuadas para ajustar su actuación a la normativa mencionada en este acto, de acuerdo con lo establecido en el citado artículo 58.2 d) del RGPD, según el cual cada autoridad de control podrá “*ordenar al responsable o encargado del*

tratamiento que las operaciones de tratamiento se ajusten a las disposiciones del presente Reglamento, cuando proceda, de una determinada manera y dentro de un plazo especificado...". La imposición de esta medida es compatible con la sanción consistente en multa administrativa, según lo dispuesto en el art. 83.2 del RGPD.

En esta propuesta de resolución de procedimiento sancionador se establece cuál ha sido la infracción cometida y los hechos que dan lugar a la vulneración de la normativa de protección de datos, de lo que se infiere con claridad cuáles son las medidas a adoptar, sin perjuicio de que el tipo de procedimientos, mecanismos o instrumentos concretos para implementarlas corresponda a la parte sancionada, pues es el responsable del tratamiento quien conoce plenamente su organización y ha de decidir, en base a la responsabilidad proactiva y el enfoque de riesgos, cómo cumplir con el RGPD y la LOPDGDD.

No obstante, en este caso, con independencia de lo anterior, procede proponer que en la resolución se ordene a la parte reclamada a que, en el plazo de 10 días hábiles desde la aceptación de la resolución, cese en la práctica de remitir la contraseña y la identificación de usuario en un único correo electrónico a los usuarios de su web, de conformidad con el artículo 32 del RGPD y remita a la AEPD la documentación acreditativa de su cumplimiento.

Debe recordarse que en el acuerdo de inicio esta Agencia acordó requerir a la parte reclamada, como medida provisional, para que cesara en la conducta descrita. Por tanto, la medida que se propone equivale a elevar a definitiva la medida provisional impuesta.

Se advierte que no atender la posible orden de adopción de medidas impuestas por este organismo en la resolución sancionadora podrá ser considerado como una infracción administrativa conforme a lo dispuesto en el RGPD, tipificada como infracción en su artículo 83.5 y 83.6, pudiendo motivar tal conducta la apertura de un ulterior procedimiento administrativo sancionador.

A la vista de lo expuesto se procede a emitir la siguiente

PROPUESTA DE RESOLUCIÓN

Que por la Directora de la Agencia Española de Protección de Datos se sancione a **COMERCIAL GIRONA DE LLIBRES, S.L.**, con NIF **B55192348**, por una infracción del Artículo 32 del RGPD, tipificada en el Artículo 83.4.a) del RGPD, con una multa de 20.000 € (veinte mil euros).

Que por la Directora de la Agencia Española de Protección de Datos se ordene a **COMERCIAL GIRONA DE LLIBRES, S.L.**, con NIF **B55192348**, que en virtud del artículo 58.2.d) del RGPD, adopte con carácter definitivo la medida provisional impuesta en el acuerdo de apertura del presente procedimiento sancionador.

Asimismo, de conformidad con lo establecido en el artículo 85.2 de la LPACAP, se le informa de que podrá, en cualquier momento anterior a la resolución del presente

procedimiento, llevar a cabo el pago voluntario de la sanción propuesta, lo que supondrá una reducción de un 20% del importe de la misma. Con la aplicación de esta reducción, la sanción quedaría establecida en 16.000 € (dieciséis mil euros) y su pago implicará la terminación del procedimiento, sin perjuicio de la imposición de las medidas correspondientes. La efectividad de esta reducción estará condicionada al desistimiento o renuncia de cualquier acción o recurso en vía administrativa contra la sanción.

En caso de que optara por proceder al pago voluntario de la cantidad especificada anteriormente, de acuerdo con lo previsto en el artículo 85.2 citado, deberá hacerla efectiva mediante su ingreso en la cuenta restringida nº **IBAN: ES00-0000-0000-0000-0000-0000 (BIC/Código SWIFT: CAIXESBBXXX)** abierta a nombre de la Agencia Española de Protección de Datos en la entidad bancaria CAIXABANK, S.A., indicando en el concepto el número de referencia del procedimiento que figura en el encabezamiento de este documento y la causa, por pago voluntario, de reducción del importe de la sanción. Asimismo, deberá enviar el justificante del ingreso a la Subdirección General de Inspección para proceder a cerrar el expediente.

En su virtud se le notifica cuanto antecede, y se le pone de manifiesto el procedimiento a fin de que en el plazo de DIEZ DÍAS pueda alegar cuanto considere en su defensa y presentar los documentos e informaciones que considere pertinentes, de acuerdo con el artículo 89.2 de la LPACAP.

926-070623

R.R.R.
INSTRUCTOR

ANEXO

Índice del expediente EXP202313871
(...)
>>

SEGUNDO: En fecha 13 de noviembre de 2024, **COMERCIAL GIRONA** ha procedido al pago de la sanción en la cuantía de **16.000,00 euros** haciendo uso de la reducción prevista en la propuesta de resolución transcrita anteriormente.

TERCERO: **COMERCIAL GIRONA** ha renunciado expresamente a cualquier acción o recurso en vía administrativa contra la sanción.

CUARTO: En fecha 2 de agosto de 2024, **COMERCIAL GIRONA** comunicó a esta Agencia la eliminación de la práctica de envío de contraseñas por correo electrónico. Aporta certificado emitido por el encargado de tratamiento, **COMERTIS ECOMMERCE SOLUTIONS, SL** con CIF **B55192048**, de fecha 24 de julio de 2024, en el que deja constancia que el 23 de junio de 2023, a las 9:00 horas, eliminaron el email automático de registro con usuario y contraseña que enviaba Prestashop desde la web de <https://comercialgirona.cat/comandes/>.

FUNDAMENTOS DE DERECHO

I

Competencia

De acuerdo con los poderes que el artículo 58.2 del Reglamento (UE) 2016/679 (Reglamento General de Protección de Datos, en adelante RGPD), otorga a cada autoridad de control y según lo establecido en los artículos 47, 48.1, 64.2 y 68.1 de la Ley Orgánica 3/2018, de 5 de diciembre, de Protección de Datos Personales y garantía de los derechos digitales (en adelante, LOPDGDD), es competente para resolver este procedimiento la Presidencia de la Agencia Española de Protección de Datos.

Asimismo, el artículo 63.2 de la LOPDGDD determina que: *"Los procedimientos tramitados por la Agencia Española de Protección de Datos se registrarán por lo dispuesto en el Reglamento (UE) 2016/679, en la presente ley orgánica, por las disposiciones reglamentarias dictadas en su desarrollo y, en cuanto no las contradigan, con carácter subsidiario, por las normas generales sobre los procedimientos administrativos."*

II

Terminación del procedimiento

El artículo 85 de la Ley 39/2015, de 1 de octubre, del Procedimiento Administrativo Común de las Administraciones Públicas (en lo sucesivo LPACAP), bajo la rúbrica *"Terminación en los procedimientos sancionadores"* dispone lo siguiente:

"1. Iniciado un procedimiento sancionador, si el infractor reconoce su responsabilidad, se podrá resolver el procedimiento con la imposición de la sanción que proceda.

2. Cuando la sanción tenga únicamente carácter pecuniario o bien quepa imponer una sanción pecuniaria y otra de carácter no pecuniario pero se ha justificado la improcedencia de la segunda, el pago voluntario por el presunto responsable, en cualquier momento anterior a la resolución, implicará la terminación del procedimiento, salvo en lo relativo a la reposición de la situación alterada o a la determinación de la indemnización por los daños y perjuicios causados por la comisión de la infracción.

3. En ambos casos, cuando la sanción tenga únicamente carácter pecuniario, el órgano competente para resolver el procedimiento aplicará reducciones de, al menos, el 20 % sobre el importe de la sanción propuesta, siendo éstos acumulables entre sí. Las citadas reducciones, deberán estar determinadas en la notificación de iniciación del procedimiento y su efectividad estará condicionada al desistimiento o renuncia de cualquier acción o recurso en vía administrativa contra la sanción.

El porcentaje de reducción previsto en este apartado podrá ser incrementado reglamentariamente."

III

Pago voluntario

De conformidad con lo dispuesto en el citado artículo 85 de la LPACAP, en la propuesta de resolución notificada se le permitía llevar a cabo el pago voluntario de la sanción propuesta, lo que supondría la reducción de un **20% de su importe**. Con la aplicación de esta reducción, la sanción quedaría establecida en **16.000,00 euros** y su pago implicará la terminación del procedimiento, sin perjuicio de la imposición de las medidas correspondientes.

Tras la citada propuesta de resolución, y antes de que se dictase resolución por parte de esta autoridad, **COMERCIAL GIRONA**, en fecha 13 de noviembre de 2024, procedió a realizar el pago voluntario, acogándose a la reducción del 20% y renunciando a cualquier acción o recurso en vía administrativa.

Debe tenerse en cuenta que, de acuerdo con los preceptos de la LPACAP, así como de la jurisprudencia del Tribunal Supremo en esta materia, el ejercicio del pago voluntario por el presunto responsable no exime a la administración de la obligación de resolver y notificar todos los procedimientos, cualquiera que sea su forma de iniciación. De igual forma, el artículo 88 de la citada norma establece que la resolución que ponga fin al procedimiento decidirá todas las cuestiones planteadas por los interesados y aquellas otras derivadas del mismo.

Por lo tanto, de acuerdo con la legislación aplicable y valorados los criterios de graduación de las sanciones cuya existencia ha quedado acreditada, la Presidencia de la Agencia Española de Protección de Datos RESUELVE:

PRIMERO: DECLARAR la comisión de las infracciones y CONFIRMAR las sanciones determinadas en la parte dispositiva de la propuesta de resolución transcrita en la presente resolución.

La suma de las citadas cuantías arroja una cantidad total de **20.000,00 euros**.

Tras haber procedido **COMERCIAL GIRONA DE LLIBRES, S.L.** al pronto pago, aunque sin reconocimiento de responsabilidad, se procede, en virtud del artículo 85 de la LPCAP, a la reducción de un 20% del total mencionado, lo cual supone la cantidad definitiva de **16.000,00 euros**.

SEGUNDO: DECLARAR la terminación del procedimiento **EXP202313871**, de conformidad con lo establecido en el artículo 85 de la LPACAP.

TERCERO: CONFIRMAR, elevándola a definitiva, la medida provisional impuesta a **COMERCIAL GIRONA DE LLIBRES, S.L.**, consistente en la suspensión del tratamiento de datos de carácter personal objeto del presente procedimiento sancionador, procediendo a la eliminación de la práctica de envío del email automático de registro con usuario y contraseña desde su web.

CUARTO: NOTIFICAR la presente resolución a **COMERCIAL GIRONA DE LLIBRES, S.L.**.

QUINTO: De acuerdo con lo previsto en el artículo 85 de la LPACAP que condiciona la reducción por pago voluntario al desistimiento o renuncia de cualquier acción o recurso en vía administrativa, por parte de la presente autoridad se acepta la renuncia

expresamente manifestada por **COMERCIAL GIRONA DE LLIBRES, S.L.**, no cabiendo en consecuencia la interposición de recurso potestativo de reposición frente a la presente resolución, todo ello sin perjuicio de la posibilidad de acudir a la vía jurisdiccional contencioso-administrativa.

En consecuencia, teniendo en cuenta lo dispuesto en el artículo 90 de la LPACAP, dado que no cabe ningún recurso en vía administrativa al haber renunciado expresamente, la presente resolución será firme y plenamente ejecutiva a partir de su notificación.

No obstante, conforme a lo previsto en el artículo 90.3 a) de la LPACAP, se podrá suspender cautelarmente la resolución firme en vía administrativa si el interesado manifiesta su intención de interponer recurso contencioso-administrativo. De ser éste el caso, el interesado deberá comunicar formalmente este hecho mediante escrito dirigido a la Agencia Española de Protección de Datos, presentándolo a través del Registro Electrónico de la Agencia [<https://sedeagpd.gob.es/sede-electronica-web/>], o a través de alguno de los restantes registros previstos en el art. 16.4 de la citada Ley 39/2015, de 1 de octubre. También deberá trasladar a la Agencia la documentación que acredite la interposición efectiva del recurso contencioso-administrativo. Si la Agencia no tuviese conocimiento de la interposición del recurso contencioso-administrativo en el plazo de dos meses desde el día siguiente a la notificación de la presente resolución, daría por finalizada la suspensión cautelar.

De conformidad con lo establecido en el artículo 50 de la LOPDGDD, la presente Resolución se hará pública una vez haya sido notificada a los interesados.

1414-15012025

Olga Pérez Sanjuán

La Subdirectora General de Inspección de Datos, de conformidad con el art. 48.2 LOPDGDD, por vacancia del cargo de Presidencia y Adjunta